

Reflection Questions:

1 - Explain the difference between authentication and authorization

- Authentication is the process of verifying who a user is, It validates the user's identity using credentials like username and passwords
- Authorization is the process of verifying what an authenticated user is allowed to do or access

2 - Why passwords never be stored in plain text?

To prevent it from:

- Data Breach Vulnerability
- Credential stuffing Risk
- Lack of internal privacy

If an attacker gains unauthorized access to the server's file system or database any password stored in plain text is instantly compromised

3. What is the purpose of password hashing

Hashing converts a plaintext password into a fixed length scrambled string of characters

It's a mathematical one-way function, it's impossible to reverse the hash back into the original password.

4. How does duplicate login prevention improve security?

- It acts as an immediate defense system by preventing an unauthorized attacker from entering a user's active session while that user is online
- It serves as instant warning that the user's credential has been stolen

5. Suggest two additional security improvements for your application

1. Implement TLS/SSL Encryption, this will enforce the Transport layer security and encrypt the raw TCP socket data in transit, preventing network sniffing
2. Adding Cryptographic Salting: it will ensure that the identical passwords yield completely different hashes, neutralizing pre-computed table exploits